LABORATUVAR 5 · GENEL SÜRÜM · Mori Seiki NH5000 DCG

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Enis UZUN | Grup Gündüz B | Tarih 06/11/2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, etkiler: (1) Bileşen var: SBOM'da Component X, PLC firmware'inde listeli. (2) Sürüm etkileniyor: 2.4, CVE'nin etkilenen aralığında. (3) Ulaşılabilir: uzak servis/ağ yolundan erişilebilir. Üçü de sağlanıyor; biri sağlanmazsa risk düşer, acil olmaz.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam. Durdurmak da risk üretir (yarım işlenmiş parça, palet ve takım durumu) ve dışarıdan sömürülmedikçe acil değildir. Önce uzak erişimi kapatır, izlemeyi artırırım; sömürü belirtisi veya doğrudan dış erişim varsa planlı olarak durdururum.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Doğrudan değil, önce test: üretici onayı alınır, PLC/parametre/NC yedeği alınır. Yama canlı makinede değil, ayrı test ortamında (yedek kontrolcü veya simülasyon) denenir; yoksa bakım duruşunda parçasız kuru çalıştırmayla. Başarılıysa planlı duruşta uygulanır, geri dönüş planı hazır tutulur.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir: PLC firmware'i kapı interlock ve STO sinyallerini işliyorsa. Anlama: yama notu ve üreticiden etkilenen modül bilgisi, safety konfigürasyonunun sürüm/checksum karşılaştırması. Yama sonrası safety validation tekrarlanır: E-stop, kapı interlock, STO ve enabling device testleri.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Compensating control: (1) Uzak erişim varsayılan kapalı; yalnız bakım penceresinde, jump server + VPN + MFA ile açılır. (2) PLC/CNC ayrı bölgeye alınır; güvenlik duvarında yalnız gerekli IP/port/protokole izin verilir, ofis ağından erişim kesilir. (3) USB ve servis portları kilitlenir, yazma yetkisi kısıtlanır. (4) Ağ izleme ve konfigürasyon değişikliği alarmı, yedek/hash karşılaştırması. (5) Safety yolu zaten bağımsızdır; yama tarihi planlanır ve risk kabulü yazılı alınır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.